SIMATS ENGINEERING

Engineer to Excel

SIMATS

Saveetha Institute of Medical And Technical Sciences

(Declared as Deemed to be University under Section 3 of UGC Act 1956)

CO1 – ASSESSMENT 03

ASSIGNMENT

Course Faculty	**:**	**Dr. M. MAYURANATHAN**
Course Name	**:**	**Ethical Hacking**
Course Code	**:**	**ITA1440**
Slot	**:**	**Slot B**
Total Marks	**:**	**100**

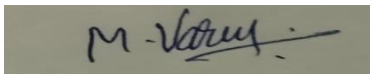
CO1 :

Apply the principle of the foundational concepts of ethical hacking, including types of hackers, ethical principles, legal frameworks, and the role of responsible disclosure in cybersecurity.

Code of Conduct:

I M. Vara Prasad (192324251) certify that this submission is my original work and that I have adhered to the guidelines specified for this assessment.

I understand that any violation of academic integrity rules will result in disciplinary action.



Signature of the student

Answer the Following

Refer the below site and pick any once disclosure and review it

https://hackerone.com/hacktivity/overview?queryString=disclosed%3Atrue&sortField=latest_disclosable_activity_at&sortDirection=DESC&pageIndex=0

Fill the following details

Case Title	A server response that answers nothing is used as the next transfer's reply — and with IMAP, a fully compliant server does this by accident
Company Name	curl
Case Link	https://hackerone.com/reports/4131903
Date Published	October 2026

Vulnerability Type *(Example: XSS, SQL Injection, IDOR, SSRF, CSRF, Authentication Bypass)*	Response misattribution / Connection state desynchronization (Improper Input Handling / Logic Flaw)
Severity *(Low / Medium / High / Critical)*	Low
Bug Bounty Reward (Mention the reward if disclosed. Otherwise write "Not Disclosed")	Not Disclosed
About the Company *(2 - 3 lines)*	curl is a widely used open-source command-line tool and library (libcurl) used for transferring data with URLs supporting numerous protocols. It is embedded in millions of software installations, operating systems, and IoT devices globally.
Purpose of the Affected Application	libcurl handles network communication across various application layer protocols (such as IMAP, POP3, SMTP, and FTP), managing socket connections, request transmission, and response parsing.
Explain the Vulnerability in Your Own Words *(Do not copy from HackerOne. Explain in simple language.)*	When a network connection is reused for multiple file transfers on specific protocols (like IMAP, POP3, SMTP, or FTP), servers sometimes send unrequested or unsolicited data lines (such as status updates or asynchronous messages). Because libcurl's ping-pong protocol parser lacks strict state tracking to link every reply directly back to its specific command, it leaves these stray bytes in the receive buffer. When the next transfer starts on that same connection, libcurl mistakenly treats the leftover unrequested line as the official response to the new command, leading to wrong content delivery, failed data transfers, or redirected connections.
Which Security Principle Was Violated? *(ConYidentiality / Integrity / Availability / Authentication / Authorization, etc.)*	Integrity (data/response integrity was compromised because messages and server responses were incorrectly matched and shifted across transfers).
How Should Developers Fix It?	1. Implement robust command-to-response mapping or correlation within the protocol parser so that unrequested responses cannot be consumed as valid answers to subsequent commands. 2. Ensure that idle connection buffers are thoroughly purged or validated upon connection reuse to clear any stray or leftover data streams before initiating a new request.
What Did You Learn from This Case? *(Write your personal learning in your own words.)*	This case highlights how complex state management across persistent network connections can lead to subtle protocol confusion bugs. Even when individual components handle parsing securely, small oversights in how connection buffers and asynchronous protocol notifications interact can result in cross-transfer data misattribution. It emphasized the importance of rigorous parser state validation, especially in multi-command protocols where servers can send asynchronous updates at arbitrary times.

RUBRICS

Criteria	Weightage (%)	Level 4 (Exemplary)	Level 3 (ProZicient)	Level 2 (Developing)	Level 1 (Beginning)
Case IdentiZication and Vulnerability ClassiZication	25%	Accurately identiDies the case, company, affected application, vulnerability type, severity, and disclosure details.	IdentiDies most case and vulnerability details correctly with minor omissions.	IdentiDies some details but misses important case information or classiDication.	Fails to correctly identify the case or vulnerability.
Vulnerability and Security Principle Analysis	25%	Clearly explains the vulnerability in own words and accurately identiDies the violated security principle such as conDidentiality, integrity, authentication, or authorization.	Correctly explains the vulnerability and security principle with minor gaps.	Provides a basic explanation but shows limited technical understanding.	Unable to explain the vulnerability or identify the relevant security principle.
Remediation and Responsible Disclosure	30%	Provides technically sound developer recommendations and demonstrates excellent understanding of responsible vulnerability disclosure.	Provides suitable remediation and demonstrates good understanding of disclosure practices.	Provides limited or partially appropriate remediation recommendations.	Recommendations are inappropriate, incomplete, or missing.
Technical Communication and Learning ReZlection	20%	Presents the case systematically using appropriate cybersecurity terminology and provides meaningful personal learning.	Presents the case clearly with suitable terminology and reasonable reDlection.	Presentation is understandable but lacks technical depth or meaningful reDlection.	Response is poorly organized, incomplete, or difDicult to understand.